

# Quarterly Threat Report: Second Quarter, 2025

**In Q2 of 2025, ransomware remained a leading threat to organizations worldwide, though the overall number of ransomware incidents reported to Beazley dropped.**

**Executive Summary**

In Q2 of 2025, ransomware remained a leading threat to organizations worldwide, though the overall number of ransomware incidents reported to Beazley dropped by about 18% compared to last quarter which included an activity spike in February 2025. Notably, industries targeted by threat actors shifted slightly, with business services taking over from healthcare as one of the most ransomed industries from a claims perspective. Financial services, education, and government remained at mostly consistent levels.



Most ransomware cases observed by Beazley Security began with stolen credentials or hijacked user sessions, often through remote access tools like VPNs and remote desktop services (RDS). The use of infostealers and credential harvesting from criminal forums likely continue to fuel these access methods. Given these attack patterns, organizations should focus on implementing and hardening modern identity and access management controls in their environments.

Looking at attack patterns mapped from Beazley Security's Managed eXtended Detection and Response (MXDR) telemetry, we see more attacks contained at an early stage – 58% in this quarter versus 48% in Q1 – with most activity pointing to recon efforts and initial access attacks in attempt to gain a foothold in client environments. We view this result as evidence of the strength and maturity of our MDR offering to identify and stop attacks in the early stages of the kill chain.

At the same time, advanced threat actors were exploiting vulnerabilities in commonly used remote monitoring and management (RMM) solutions, hoping to capitalize on one-to-many victim opportunities by compromising upstream providers. The CitrixBleed2 vulnerability made headlines this quarter and emerged as an especially severe flaw affecting Citrix NetScaler devices, which experienced in-the-wild exploitation detailed later in this report.

Other notable developments in the threat landscape include:

- Heightened law enforcement activity resulting in the notorious cybercrime forum BreachForums v2 being taken down;
- Efforts from Operation ENDGAME disrupting underground malware as a service ecosystems;
- Increased attacks by Iranian-linked threat actors due to continued tensions in the Middle East; and
- The expansion into new sectors by the Scattered Spider group.

In this quarter's report, we provide a closer look at these developments and trends and offer insights to help organizations better prepare for what's ahead in the second half of 2025.

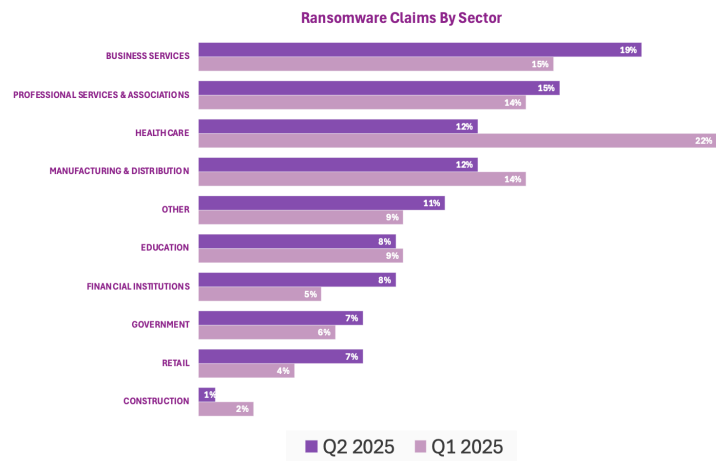
## Q2 2025 Key Takeaways

- Ransomware activity remained a persistent and complex threat this quarter, with ransomware incidents dropping about 18% compared to Q1 2025, as an activity spike in February 2025 subsided.
- Qilin was the most active ransomware group being tracked by Beazley Security, with the actor claiming 226 attacks on their public leak site.
- As in Q1, compromised credentials led to the most ransomware cases, with compromised credentials at 36% and compromised remote desktop services (RDS) credentials at 25%. 
- Q2 saw a small decline in actively exploited vulnerabilities, down 13% compared to last quarter.
- MXDR telemetry showed a shift toward earlier detections, with early-stage containment jumping from 48% of attacks to 58% in Q2.
- Attackers have continued the trend of exploiting remote monitoring and management (RMM) solutions this quarter, especially SimpleHelp and ConnectWise.
- Edge devices from Ivanti, Fortinet, SonicWall, and Citrix have shown increasing vulnerabilities, which threat actors have exploited in the wild.
- A critical vulnerability in CrushFTP file transfer software was quickly exploited by Medusa, demonstrating the speed at which the group can capitalize on newly discovered vulnerabilities.
- The CitrixBleed2 vulnerability emerged this quarter and experienced active exploitation and attack patterns similar to the original CitrixBleed vulnerability identified in 2023.
- Operation ENDGAME, a multinational law enforcement initiative, demonstrated significant success, disrupting several global cybercrime networks, taking down over 300 servers worldwide, neutralizing 650 related domains, and seizing around \$4.7 million (USD) in cryptocurrency.
- Tensions in the Middle East have led to increased activity from Iranian-linked threat actors.
- Scattered Spider escalated its cybercrime operations in June by expanding from retail to the insurance and aviation sectors, including partnering with established ransomware-as-a-service (RaaS) groups to form an enhanced supply chain threat.
- One of most prominent English-language cybercrime markets, BreachForums v2 stopped operating in April 2025, with several forum administrators arrested by law enforcement in June.

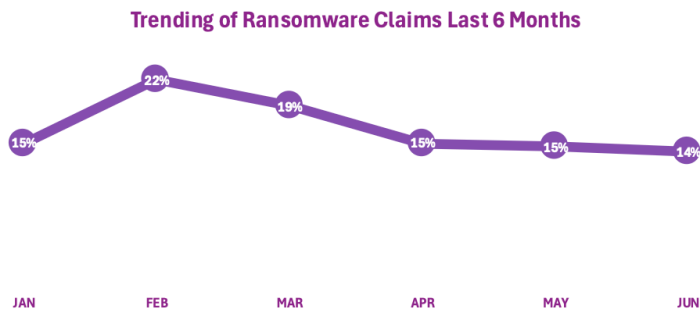
## Ransomware Overview

Ransomware activity remained a persistent threat in Q2; even as ransomware incidents reported to Beazley dropped nearly 18%, as an activity spike in February 2025 subsided. While the downward trend is encouraging, the distribution of attacks across industry sectors has shifted slightly in past months, revealing a change in which industries ransomware threat actors are targeting.

Notably, healthcare sector incidents declined sharply, falling from 22% of ransomware incidents observed to 12% in Q2. The drop across the sector could suggest a pivot in opportunistic threat actors toward industries that are perceived as either softer or higher-value targets.



Meanwhile, business services and professional services saw a slight increase in targeting, with business services rising from 15% to 19% of ransomware claims in Q2. As both sectors often support multiple clients and systems, they remain attractive targets for ransomware actors aiming to scale in operations. Manufacturing and distribution also saw a modest increase in overall ransomware incidents, highlighting disruption of operational technology environments which might result in the direct operational downtime of a victim.



As ransomware claim trends decline moderately in Q2 from a spike in Q1, ransomware impacts remain significant. Later in this report, Beazley Security describes in detail how threat actors are targeting and exploiting software used by third-party vendors to provide technical support, monitoring, and IT management services.

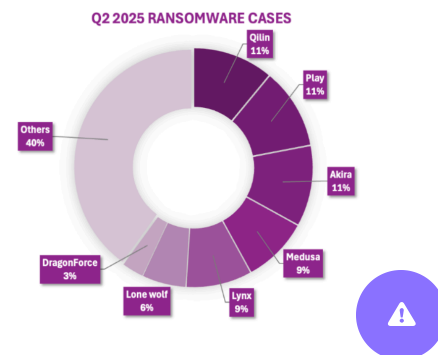
## Ransomware Incident Trends

In the field, Beazley Security incident responders observed a wider variety of threat actors, with Play, Qilin, and Akira each roughly responsible for the same number of incidents.

Compared to last quarter, where activity was more concentrated among a few ransomware groups, our team observed a broader distribution, with no single group exceeding 11% of total

cases. This trend suggests some decentralization within ransomware ecosystems as groups like RansomHub were absorbed by DragonForce, and law enforcement activity may be further impacting cybercriminal supply chains.

Of ransomware actors observed by incident responders this quarter, the three that stood out by case percentages are documented below:



- **Qilin:**

Also known as Agenda, Qilin were first observed around July 2022. The group, like most modern ransomware operators, practice double extortion, exfiltrating data before encrypting it, and demanding ransoms for both decryption and the promise to delete stolen data. They've been known to exploit victims through phishing emails, malicious attachments, and compromised remote desktop protocols (RDP). The group is linked to many high-profile cyberattacks, including [incidents targeting governments](#) and healthcare organizations. Qilin accounted for approximately 11% of Beazley Security IR cases in Q2 and had the highest public leak site activity this quarter, claiming 226 posts on their public leak site.

- **Akira:**

Akira has been active since early 2023 and also employs double extortion tactics. The group typically gains initial access by exploiting known vulnerabilities in VPN appliances and remote services, often targeting unpatched systems or weak credentials. They have [targeted various sectors](#) including manufacturing and education. Akira accounted for approximately 11% of Beazley Security IR cases in Q2 and claimed 135 posts on their public leak site this quarter.

- **Play:**

Play emerged in mid-2022. Play actors have been known to exploit vulnerabilities in Microsoft Exchange, Fortinet appliances, and RDP services to gain initial access. They use a double extortion model and often contact victims via email or phone to pressure payment, sometimes impersonating IT support to gain remote access into victim environments. They have [targeted a wide range of industries](#), including government, media, and healthcare. Play accounted for approximately 11% of Beazley Security cases in Q2 and claimed 123 victims publicly on their site this quarter.

## INITIAL ACCESS RESULTING IN RANSOMWARE DEPLOYMENTS

Understanding how threat actors gain initial access is critical to preventing ransomware attacks. Before they're able to detonate ransomware or exfiltrate files, attackers must first establish a foothold, often through vulnerabilities in edge devices, phishing, or stolen credentials.

Pinpointing the initial entry point during an investigation, however, is often challenging. Many organizations lack the necessary logging or visibility to support effective forensic analysis, and attackers frequently take deliberate steps to erase evidence, making their entry even harder to trace.

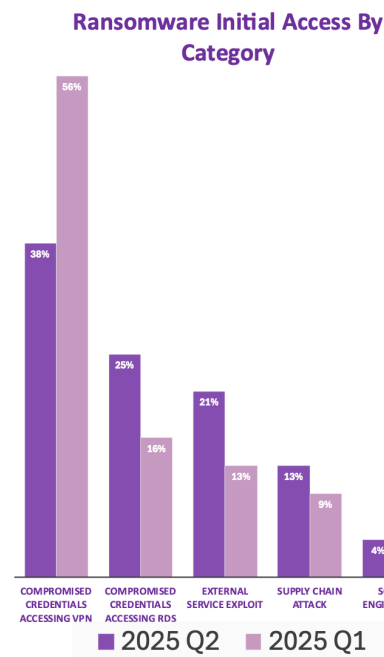
Most ransomware actors operate opportunistically, yet consistent initial access trends still emerge. These patterns are driven by a combination of factors, including the emergence of zero-day vulnerabilities in enterprise environments, seasonal shifts in behavior based on geopolitical events, and pivots to more rewarding or less detectible attack methods.

In Q2, Beazley Security tracked initial access vectors across ransomware engagements, and much like in Q1, compromised valid credentials were the leading method ransomware actors used to opportunistically access an environment. Our team observed a steady stream of cases where ransomware actors successfully gained access by targeting VPNs and Windows Remote Desktop Services (RDS) with compromised, valid credentials.

A variety of known methods are used to gain access with compromised credentials, including password stuffing with password “combo-lists” made available on criminal forums, brute-forcing service accounts, and purchasing credentials from initial access brokers who sell stolen credentials on cybercriminal markets. Additionally, failure to implement multi-factor authentication (MFA) gives threat actors an easy way to get a foothold within an organization, often bypassing other perimeter defenses entirely.

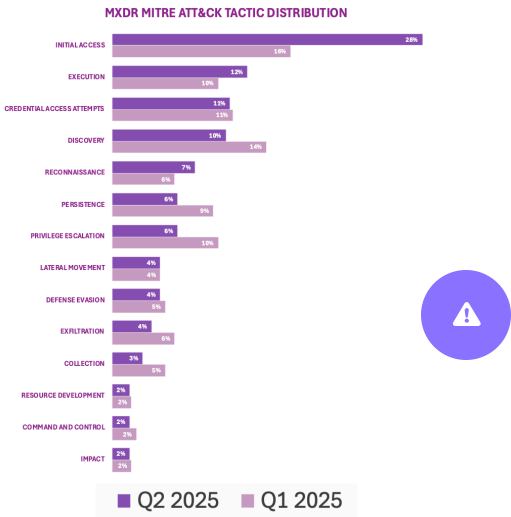
Ransomware actors in Q2 also continued to exploit authentication bypass vulnerabilities reported earlier this year in popular external services. Notably, older flaws in various [Fortinet](#) firewall products and another in the [CrushFTP](#) file transfer software continue to trend, allowing attackers to bypass standard authentication checks and gain unauthorized access to sensitive data without valid credentials. Both vulnerabilities have confirmed in-the-wild exploitation, with the ransomware groups leveraging them in ongoing attacks.

Other ransomware actors are continuing to exploit vulnerabilities disclosed last quarter in remote monitoring and management (RMM) solutions like [ConnectWise](#) and [SimpleHelp](#). Targeting a single RMM vendor allows threat actors to achieve a one-to-many attack, compromising multiple downstream customers of the RMM in a single campaign, as we describe below.



## Beazley Security MDR Trends and Overview

During Q2, Beazley Security’s MDR teams responded to a wide range of incidents across client environments. Most response activity centered on the early and middle stages of the attack kill chain, which mirrors the trends of Q1. Initial access, execution, and credential access attempts emerged as the most frequently observed MITRE ATT&CK tactics, which highlights a strong focus by threat actors on reconnaissance and lateral movement within target environments.



MXDR telemetry shows a shift toward earlier detections in Q2, with early-stage containment jumping from 48% of attacks to 58%. This aligns with a rise in the distribution of initial access detections mentioned above from ~16% in Q1 to ~28% this quarter, showcasing that Beazley Security MXDR is able to identify and contain threats closer to the intrusion point. Telemetry also indicated a slight rise in the total number of attacks observed.

The activity we observed this quarter aligns with opportunistic, automated campaigns where attackers exploit initial access vectors and rapidly attempt to expand their foothold. Additionally, threat actors continue to leverage “malvertising” campaigns to disseminate malicious software as described below. This can be observed in trend data as increased containment activity at the execution stage of attack chains highlights the importance of implementing and maintaining strong preventative endpoint controls and behavioral detection capabilities for these types of attacks.

Overall, telemetry trends in Q2 show fewer distribution of attacks reached critical stages of persistence and privilege escalation, evidence that early detections and containment are preventing progression.

| Attack Phase         | Q1% | Q2% | Descriptions                                                                            |
|----------------------|-----|-----|-----------------------------------------------------------------------------------------|
| Early-stage Attacks  | 48% | 58% | Usage of credential access attempts and discovery detected and contained                |
| Middle-stage Attacks | 38% | 33% | Attempts to sustain and expand adversarial control within client environments contained |
| Late-stage Attacks   | 14% | 9%  | Critical threats such as data exfiltration and ransomware deployments contained         |

# INCREASING USE OF MALVERTISING

As mentioned above, a continued trend observed across Beazley MXDR clients were threat actors advertising seemingly benign productivity tools, such as free PDF converters, as lures to compromise unsuspecting users. These tools are often marketed as lightweight utilities to convert or edit documents, appealing to users looking for a quick solution. Once downloaded, this software may perform its advertised function to avoid any suspicion, but behind the scenes it may upload converted documents to attacker-controlled infrastructure. The fallout from this could expose potentially sensitive personal or company confidential information, harvesting this data without the user's knowledge.



Beyond data exfiltration, these advertised tools may be trojanized or bundled with time-delayed malware. In one campaign, suspicious activity stemming from a free PDF conversion tool named PDFFast was observed by Beazley Security's MXDR team. The installed "freemium" software had been downloaded to endpoints and installed a "sleeping" updater. One evening, the software initiated an unusual update routine that downloaded and executed obfuscated binaries around the same time across several monitored environments.

Once executed, the suspect software performed advanced system reconnaissance and checks for system virtualization – red flags for sandbox evasion - behaviors atypical of legitimate PDF conversion software. MXDR analysts quickly detected, contained, and built custom signatures to protect clients against any future installation attempts of this software. Because we observed the anomalous activity across multiple clients, Beazley Security Labs started in-depth [analysis](#) on this software and parts of the "sleeping" updater and attack chain, discovering usage of [pyarmor-protected](#) payloads within the malware authors attack chain.

Building on the theme of malicious software being promoted under the guise of legitimacy, our MXDR team also observed threat actors blending legitimate administrative tools with payloads to deceive admins into downloading malware. "Malvertized" tool installers are promoted by threat actors to appear on search engine ads and third-party download sites, appearing as trusted versions of popular admin tools used to make administration of systems easier. Once executed, the legitimate functionality typically remains intact, while malware is silently deployed in the background running in the context of the admin's user account.

In one such example, MXDR teams detected and contained a trojanized version of PuTTY within a client's environment. Once executed by the end user, the bugged admin tool attempted to run malicious code and install a persistent backdoor via scheduled task. The goal appeared to be long-term access to gain privileged credentials of an admin, making the situation particularly dangerous. MXDR teams contained and removed this threat before any lateral movement could occur. This incident highlights how even trusted admin tools can be weaponized, emphasizing the

need for strong detection capabilities and awareness around the risks of downloading software from unofficial or ad-driven sources.

# Vulnerability Trends and Overview

Beazley Security Labs (BSL) continuously monitors published software vulnerabilities. These often number in the hundreds each day, ultimately totaling thousands per month. From this volume, research prioritizes high-impact, remotely exploitable vulnerabilities in products widely used across our client base. This targeted approach helps us deliver focused advisories and mitigation strategies.

Below is a quarter-over-quarter comparison of publicly disclosed vulnerabilities for Q2.

| Vulnerability Trends                       | Q2 2025 | Change from Q1 |
|--------------------------------------------|---------|----------------|
| New CVEs published by NIST                 | 11,736  | - 2.51%        |
| CVEs added to CISA KEV                     | 39      | - 13%          |
| Critical 0-Day advisories published by BSL | 8       | + 0%           |

\*Critical BSL advisories are made publicly available [here](#).

Total CVE volume is down slightly from last quarter, and while CISA added fewer CVEs added to CISA’s Catalogue of Known and Exploited Vulnerabilities (KEV), the ones that did make it onto KEV were used in several wide-ranging threat actor campaigns. The most notable were ScreenConnect (CVE-2025-3935), CrushFTP (CVE-2025-31161), and “CitrixBleed 2” (CVE-2025-5777).

## ONE TO MANY: RMM VULNERABILITES FUEL DOWNSTREAM COMPROMISE

RMM tools remain an attractive target for threat actors looking to maximize impact with minimal effort. By compromising a single vendor, attackers can potentially gain access to a wide swath of downstream customers, making these tools a powerful launch pad for supply chain attacks. Ongoing activity involving ConnectWise and SimpleHelp highlight how threat actors are actively exploiting these platforms to extend reach and efforts across multiple organizations.

In the case of ConnectWise, attackers have [abused flaws in ASP.NET ViewState](#), a mechanism used to maintain the state of a webpage during user interaction. By leveraging available machine keys used by ViewState, attackers can craft malicious payloads that enable remote code execution when processed by ConnectWise servers. Although exploitation requires access to machine keys, Microsoft Threat Intelligence confirmed real-world abuse of this technique, prompting ConnectWise to release patches aimed at addressing the issue.



With SimpleHelp, threat actors have continued to exploit vulnerabilities identified earlier this year in their Remote Support Software. The first is a directory traversal flaw ([CVE-2024-57727](#)) that allows unauthenticated attackers to download sensitive configuration files, which often contain technician credentials. By using these credentials, attackers can connect to vulnerable servers, access systems remotely managed within the server interface, and pivot deeper into managed environments. [A case in June](#), which Beazley Security Labs provided research and support for, was recently disclosed by CISA and underscores the impact of threat actors targeting RMM software deployed by upstream vendors. Ransomware actors used the flaw to compromise a utility billing software provider and target them for double extortion, reflecting the potential downstream client impacts stemming from this vulnerability.

Additional flaws in the SimpleHelp software enable privilege escalation ([CVE-2024-57726](#)) and remote code execution ([CVE-2024-57728](#)). When chained together, these vulnerabilities lead to full server compromise. Exploits for these issues have been made available on an easy-to-use and freely available exploitation tool called Metasploit, and CISA added them to its KEV catalog last quarter. The ease with which attackers can exploit these vulnerabilities, including the possible downstream impact on multiple victims, makes SimpleHelp a continued high-value target for threat actors.

During Q2, BSL also observed continued trending of critical vulnerabilities in other popular edge devices:

- **Ivanti Vulnerability**

In early April, Ivanti disclosed a critical vulnerability ([CVE-2025-22457](#)) affecting their Connect Secure, Policy Secure, and ZTA Gateway products. Successfully exploiting this vulnerability could allow an unauthenticated attacker to achieve remote code execution (RCE) on a target device. Because these products are typically deployed as internet-facing infrastructure, the flaw presented a significant risk by potentially granting initial access to organizational environments.

- **SonicWall Vulnerabilities**

In early May, several vulnerabilities were identified in SonicWall Secure Mobile Access (SMA): Initially, an arbitrary file read vulnerability ([CVE-2024-38475](#)) and a command injection vulnerability ([CVE-2023-44221](#)) were reported. When combined, these vulnerabilities could grant a threat actor RCE on a target device and initial access into an organization's network. A

report by watchTowr Labs identified in-the-wild exploitation, and the same day the vulnerabilities were [added to the CISA known exploited vulnerabilities \(KEV\) catalog](#). This prompted SonicWall to update their own advisories to reflect the increased risk and severity. A week later, Rapid7 reported three new vulnerabilities ([CVE-2025-32819](#), [CVE-2025-32820](#), and [CVE-2025-32821](#)) affecting SonicWall SMA. These could be exploited to achieve RCE if an attacker had a valid login account to a target SonicWall SMA device. However, the previously mentioned CVE-2024-38475 vulnerability provided an authentication bypass, potentially allowing an alternative exploit chain for RCE that didn't require valid login credentials.



- **Fortinet Vulnerabilities**

In mid-May, Fortinet published an advisory detailing a critical buffer overflow vulnerability ([CVE-2025-32756](#)) affecting FortiVoice, FortiMail, FortiNDR, FortiRecorder, and FortiCamera. The flaw allowed unauthenticated attackers to execute arbitrary code by sending malicious HTTP cookies to exposed administrative interfaces. Fortinet confirmed active exploitation in the wild, particularly targeting FortiVoice systems, which are often directly exposed to the internet. Post-exploitation activity revealed credential harvesting, crash log erasure, and malware deployment, highlighting the severity of the threat.

- **Citrix Vulnerabilities**

In June, two critical vulnerabilities, including “CitrixBleed 2,” were confirmed as affecting Citrix NetScaler ADC and Gateway products. For more information on these vulnerabilities, see the CitrixBleed 2 section below.

This series of vulnerabilities affecting edge devices this quarter demonstrates a troubling trend. These devices serve as potential gateways into enterprise networks, and when compromised, they provide attackers with a direct path to sensitive data. BSL will continue to monitor this situation to stay ahead of evolving threats and provide timely advisories as new vulnerabilities emerge.

## CRUSHFTP VULNERABILITY EXPLOITED BY MEDUSA RANSOMWARE ACTORS

In April, Beazley Security Labs released an [advisory](#) on FTP software suite CrushFTP, due to a critical authentication bypass vulnerability (CVE-2025-31161) after a public proof-of-concept was released. The flaw allowed attackers to gain full control over vulnerable servers, many of which are internet facing by design.

In the same month, Beazley Security incident responders observed Medusa ransomware operators quickly leverage this exploit to begin a campaign to deploy ransomware on vulnerable victims' systems. As of April 4th, it was believed by [Censys](#) that nearly 7500 instances of

CrushFTP were accessible from the internet, and almost 300 could be running a version vulnerable to the exploit.

Medusa's swift exploitation of this exploit demonstrates how quickly the group can integrate new vulnerabilities into their attack playbook and underscores the urgency for organizations to patch known external-facing vulnerabilities promptly.



## CITRIXBLEED 2

In June, BSL reported on a critical vulnerability dubbed "CitrixBleed2" ([CVE-2025-5777](#)), which made headlines after it was revealed that attackers could exploit a flaw in Citrix NetScaler systems. By sending malicious requests to the login function of internet-facing NetScaler services, attackers were able to trigger memory leaks that exposed sensitive data such as authentication session data. Citrix NetScaler is widely used in enterprise environments to secure and manage remote access to internal applications, so this vulnerability has wide-reaching consequences.

The vulnerability's disclosure quickly escalated into active exploitation, even as Citrix remained largely silent on in-the-wild attacks. Security researcher Kevin Beaumont [later identified](#) exploitation attempts dating back to June 23, where attackers appeared to use the flaw to leak and hijack unencrypted session data. This allowed them to bypass modern authentication mechanisms like MFA and gain unauthorized access to enterprise systems.

CitrixBleed2 was disclosed alongside another vulnerability, [CVE-2025-6543](#), which was the first of the flaws confirmed as actively exploited. This flaw led to denial-of-service (DoS) attacks and was added to CISA's Known Exploited Vulnerabilities (KEV) catalog, even before Citrix acknowledged any active exploitation of the primary CitrixBleed2 vulnerability.

The name "CitrixBleed2" is a nod to its predecessor, CitrixBleed ([CVE-2023-4966](#)), first identified in October 2023. These vulnerabilities share similar attack patterns and impact. Both flaws allow attackers to exploit memory disclosure issues in NetScaler devices using exposed session tokens, allowing session hijacking without MFA. The original CitrixBleed was also heavily exploited by ransomware groups and [affected high-profile organizations](#) like Xfinity, Boeing, and Toyota.

## Key Observations in the Threat Landscape

### OPERATION ENDGAME AND IMPACTS TO INFOSTEALER ECOSYSTEM

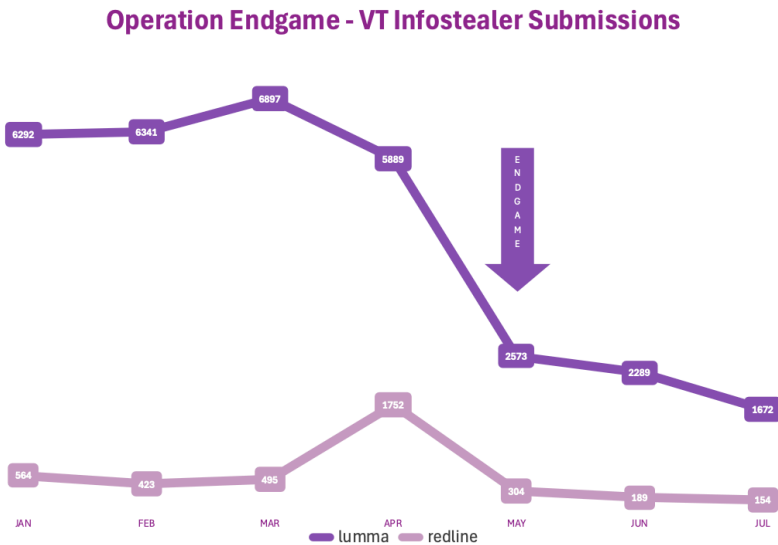
BSL has been monitoring sweeping enforcement activity regarding [Operation ENDGAME](#), which has taken action to disrupt cyber threats in recent weeks. Operation ENDGAME represents one of

the most significant international law enforcement efforts against cybercrime infrastructure in recent history. The effort is led by Europol and Eurojust and includes coordinated operations with Canada, Denmark, France, Germany, the Netherlands, the UK, and the United States. The operation has specifically targeted initial access malware, or tools often used by threat actors to gain initial access into a victim’s environment, leading to subsequent impacts such as ransomware deployments and data theft.



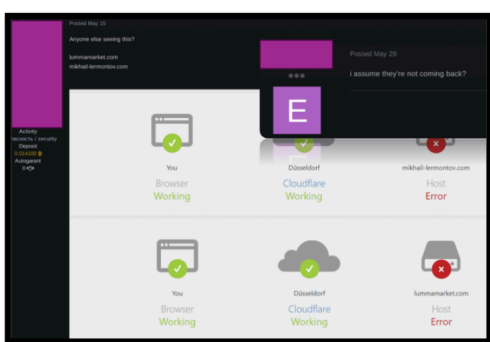
In May of 2025, Operation ENDGAME disrupted several global cybercrime networks, taking down over 300 servers worldwide, neutralizing 650 related domains, and [seizing](#) ~\$4.7 million USD in cryptocurrency. Enforcement authorities issued 20 international arrest warrants and added 18 suspects to the EU’s Most Wanted list. Among the disrupted malware families were key enablers of ransomware-as-a-service (RaaS) operations, including LummaStealer and RedLine, both of which are widely used to exfiltrate credentials, crypto wallets, and browser data that enable broader compromise.

The impact is observable in the research which illustrates VirusTotal submission volumes for Lumma and Redline dropping sharply following the May 2025 enforcement action as an indicator of disruption in the specific infostealer family usage.



The Lumma family of infostealers saw a dramatic drop from over 5,800 submissions in April to just over 2,500 in May. As two of the most prevalent stealers leveraged in initial access brokering, their decline signals a fracture in the supply chain many ransomware groups rely on.

Indicators of the impact were quickly apparent on underground forums, where actors flagged outages of Lumma-linked infrastructure returning host errors on its delivery networks. Images posted suggested backend Malware-as-a-Service servers were also taken offline, likely result of the enforcement activity.



Beyond infrastructure takedown, authorities also secured and shared credentials from over 15.4 million breached accounts, which were then [shared](#) with [Have I Been Pwned](#) to help impacted victims recover their credentials.

The recent developments highlight the increasing effectiveness of coordinated international law



enforcement efforts, not only in disabling malware ecosystems but measurably reducing threat actor activity as visible in the wild.

## IRANIAN ESCALATIONS

Middle East tensions escalated into air and missile strikes in June, resulting in both the US Government and Western-based information security communities increasing monitoring and awareness of offensive cyber operations from Iranian-linked threat actors. In response, the US Government has released several advisories and guidance documents from various agencies, including [IT-ISAC/Ag-ISAC](#), [DHS](#), and [CISA](#). These advisories detail how the ongoing Israel-Hamas and Israel-Iran conflicts have intensified threats against US networks, Israeli institutions, and allies.

As part of this escalation, several nominally independent hacktivist groups performed disruption attacks favorable to Iran. Unlike traditional cybercrime groups, these hacktivist groups are less motivated by profit and more by ideological motives. They seek to embarrass or retaliate against perceived enemies of a nation state—in this case, Iran. Three prominent attacks are notable:

- The Cyber Fattah movement [leaked athlete data](#) from the Saudi Games.
- Homeland Justice [disrupted public services](#) in the Albanian capital.
- Charming Kitten [launched phishing attacks](#) against political targets.

These attacks exemplify a strategic approach. High-profile events, such as the attack on the Saudi Games, are often the subject of attack to maximize psychological impact and notoriety. Other common targets include academics, political officials, or media outlets that produce content perceived as undermining the interests of Iran. Charming Kitten's continued targeting of journalists, researchers, and low-level staff at political institutions highlights this tactic. Direct attacks on government institutions are also typical. Homeland Justice, for example, cited Albania's willingness to provide political refuge to an opposition group as motive for their attack.

Advanced persistent threat (APT) groups with more direct connections to the Islamic Revolutionary Guard Corps (IRGC) have also been active, though not quite as visible. BSL has

analyzed some shared malware samples verified to have been used in current offensive cyber campaigns from Iran.

Most of these samples are destructive in nature, with functionality to quickly destroy systems (commonly referred to as ‘wipers’).

## SCATTERED SPIDER ACTIVITY



Scattered Spider made headlines in Q2 as they escalated operations from retail industries to insurance and aviation. The group is considered especially dangerous due to their exceptional ability to target both processes and technology in their attacks. Advanced social engineering techniques combined with deep technical understanding allow them to bypass traditional security controls and checks, often targeting helpdesk and service desk personnel to exploit provisioning processes and gain access to enterprise environments. The group leverages MFA bypass techniques with advanced phishing toolkits like [evilginx](#) to grab access tokens. Notable insurance sector organizations [targeted](#) from the group in Q2 included Aflac, Erie Insurance, and Philadelphia Insurance Companies.

Once in an environment, the group has also been known to partner with ransomware actors such as DragonForce. By aligning with ransomware operators, Scattered Spider has enhanced their capabilities in cyber extortion, which leads to even more destructive outcomes. Organizations and industries targeted should anticipate complex, multi-faceted attacks as the group maps out and exploits the human layer as much as a tech stack.

Scattered Spider activity has not gone unnoticed as the high-profile attacks have triggered increased international law enforcement interests. In June, multiple [coordinated arrests](#) took place in the UK of suspects believed to be involved in previous retail-sector intrusions linked to the group. This echoes the broader trend of agencies becoming more proactive in targeting cybercriminal ecosystems like initial access brokers, cybercriminal forums, and commodity infostealer platforms like Lummastealer that provide threat actors initial access into victim environments.

## BREACHFORUMS TAKEDOWN

BreachForums v2 was one of the most active and well-known cybercrime forums, acting as a place for threat actors to advertise data breaches, share exploits, and coordinate other illicit activities. Its ease of membership and access on the clear web made it one of the more prominent English-language cybercrime forums used for trading and selling stolen data, compromised credentials, and other leaks. Threat actors would use the forum to share breach announcements and advertise services.

Although not the first [shutdown](#) of the forum, BreachForums v2 stopped operating unexpectedly in April 2025, with security researchers speculating law enforcement activity may have been involved. In February, the arrest of Kai West – a previous admin popularly known as IntelBroker on the forum – has led to a recently unsealed [indictment](#) claiming Kai accessed protected computers to defraud victims and obtain valuable data, along with committing wire fraud and other counts of cybercrime. The indictment goes on to state that the FBI believes West and co-conspirators caused victim loss of at least \$25 million.



Only a few months later, admins of the forum posted a PGP-signed [statement](#) on the forum, suggesting that a zero-day vulnerability in the open-source platform MyBB was to blame, leaving the forum “subject to infiltration” by law enforcement, and that the site had been shut down to perform incident response. In June, enforcement efforts again escalated when French police [arrested](#) four additional operators believed to be a part of the forum’s administrator team. The members were purportedly involved in high-profile leak operations that fueled the forum’s notoriety.

In the aftermath of BreachForums v2’s takedown, many displaced members have migrated to alternative platforms such as DarkForums, Exploit, and closed Telegram communities. Of these, DarkForums has emerged as a key successor, attracting an influx of former BreachForums users seeking an alternative. While many would regard DarkForums as previously holding a lower-tier reputation in the underground, it has increased credibility with the flood of new members.

The collapse of BreachForums v2 has led to a fragmentation of its users for now, but not a permanent disruption in cybercriminal activity as members move on to other communities and cybercrime channels. If law enforcement efforts continue to grow more targeted and effective, future cybercriminal networks may increasingly be forced to leverage decentralized, invite only communities with higher barriers of entry.

## Sources

- <https://labs.beazley.security/advisories/BSL-A1118>
- <https://labs.beazley.security/advisories/BSL-A1106>
- <https://labs.beazley.security/advisories/BSL-A1120>
- <https://labs.beazley.security/advisories/BSL-A1110>
- <https://labs.beazley.security/advisories/BSL-A1084>
- <https://github.com/dashingsoft/pyarmor>
- <https://www.cisa.gov/news-events/cybersecurity-advisories/aa25-163a>
- <https://www.operation-endgame.com/news/>
- <https://reliaquest.com/blog/breachforums-arrest-fbi/>

- <https://intel471.com/blog/breachforums-saga-continues-whats-next>
- <https://www.zerofox.com/intelligence/breachforums-and-notorious-actors-announce-re-emergence/>
- <https://www.justice.gov/usao-sdny/media/1404616/dl?inline>
- <https://www.connectwise.com/company/trust/security-bulletins/screenconnect-security-patch-2025.4>
- <https://www.cisa.gov/news-events/alerts/2025/05/01/cisa-adds-two-known-exploited-vulnerabilities-catalog?ref=labs.watchtower.com>
- <https://censys.com/advisory/cve-2025-31161>
- <https://doublepulsar.com/citrixbleed-2-exploitation-started-mid-june-how-to-spot-it-f3106392aa71>
- <https://securityboulevard.com/2025/06/scattered-spider-targets-aflac-other-insurance-companies/>
- <https://www.cisa.gov/guidance-addressing-citrix-netscaler-adc-and-gateway-vulnerability-cve-2023-4966-citrix-bleed>
- <https://arstechnica.com/security/2023/12/hack-of-unpatched-comcast-servers-results-in-stolen-personal-data-including-passwords/>
- [https://www.theregister.com/2025/06/25/paris\\_police\\_claim\\_arrests\\_of/](https://www.theregister.com/2025/06/25/paris_police_claim_arrests_of/)
- <https://www.reporternews.com/story/news/2025/06/02/city-of-abilene-in-full-network-shutdown-after-cyber-attack-ransom-demand/83998511007/>
- <https://hackread.com/breachforums-displays-message-shutdown-mybb-0day-flaw/>
- <https://www.techradar.com/pro/security/hitachi-vantara-takes-down-important-systems-following-akira-ransomware-attack>
- <https://www.bankinfosecurity.com/aha-warns-hospitals-about-latest-play-ransomware-threats-a-28659>
- <https://securityboulevard.com/2024/11/how-to-prevent-evilginx-attacks-targeting-entra-id/>
- <https://nvd.nist.gov/vuln/detail/CVE-2024-57726>
- <https://nvd.nist.gov/vuln/detail/CVE-2024-57727>
- <https://nvd.nist.gov/vuln/detail/CVE-2024-57728>
- <https://nvd.nist.gov/vuln/detail/CVE-2025-22457>
- <https://nvd.nist.gov/vuln/detail/CVE-2024-38475>
- <https://nvd.nist.gov/vuln/detail/CVE-2023-44221>
- <https://nvd.nist.gov/vuln/detail/CVE-2025-32819>
- <https://nvd.nist.gov/vuln/detail/CVE-2025-32820>
- <https://nvd.nist.gov/vuln/detail/CVE-2025-32821>



- <https://nvd.nist.gov/vuln/detail/CVE-2025-32756>
- <https://nvd.nist.gov/vuln/detail/CVE-2025-5777>
- <https://nvd.nist.gov/vuln/detail/CVE-2025-6543>



# More Insights

[View All >](#)

|                                                                                                       |                                                                                                                   |                                                                                                               |
|-------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------|
|                       |                                 |                            |
| <h2>Third-Party Risk Monitoring Factsheet</h2> <p>Beazley Security's Third-Party Risk Monitori...</p> | <h2>Quarterly Threat Report: First Quarter, 2026</h2> <p>The first quarter of 2026 started with a lull and...</p> | <h2>Quarterly Threat Report: First Quarter, 2026</h2> <p>A majority of ransomware activity resulted in...</p> |



between Beazley Security and Beazley plc and/or its affiliates and subsidiaries; however, such information will not be used to inform the underwriting or claims decisions of any Beazley insurance affiliate, unless the customer agrees to disclose such information for that purpose.

